

Authentication Forte et Authentication MFA

Cybersécurité des Systèmes
informatiques

BREVET DE TECHNICIEN SUPERIEUR
SCHOLA NOVA

>
_
SSH 

PuTTY



JOSUE VERAND NGUIE

Responsable de formation:
Aymeric THYBAULT

Objectifs

L'objectif de ce TP est de configurer une authentification SSH en deux facteurs (2FA) sur un serveur Linux Mint. L'authentification se fera via un mot de passe classique et un code OTP (One-Time Password).

Prérequis

- Un serveur Linux Mint (version récente)
- Un accès root ou des privilèges sudo
- Un client SSH pour tester la connexion
- Un smartphone avec une application d'authentification (Google Authenticator, FreeOTP, etc.)

Préparation de l'environnement

1.1. Installation des Machines Virtuelles

Ici il est question de préparer notre environnement virtuel.

- Se munir de l'image ISO de linux Mint
- Créer la machine virtuelle avec VMware ou tout autre hyperviseur

Configuration Réseau des VM

nous allons nous assurer que notre VM soit en nat afin qu'elle puisse échanger avec notre machine physique en local et qu'elle communique en SSH.

-Pour tester la connectivité on va commencer par un ping entre les deux machines

-Pour la connexion au niveau d'internet nous allons pinguer l'adresse 8.8.8.8.

```
root@mint-seveur:~# ping 192.168.0.16
PING 192.168.0.16 (192.168.0.16) 56(84) bytes of data.
64 bytes from 192.168.0.16: icmp_seq=1 ttl=128 time=0.886 ms
64 bytes from 192.168.0.16: icmp_seq=2 ttl=128 time=1.29 ms
64 bytes from 192.168.0.16: icmp_seq=3 ttl=128 time=0.994 ms
^C
--- 192.168.0.16 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2003ms
rtt min/avg/max/mdev = 0.886/1.056/1.289/0.170 ms
root@mint-seveur:~# ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
64 bytes from 8.8.8.8: icmp_seq=1 ttl=128 time=16.8 ms
64 bytes from 8.8.8.8: icmp_seq=2 ttl=128 time=30.1 ms
^C
```

Installation service SSH



Le screen précédant révélant que notre serveur peut communiquer avec notre machine physique en local et a accès à internet, nous pouvons passer à l'installation du service SSH sur notre serveur.

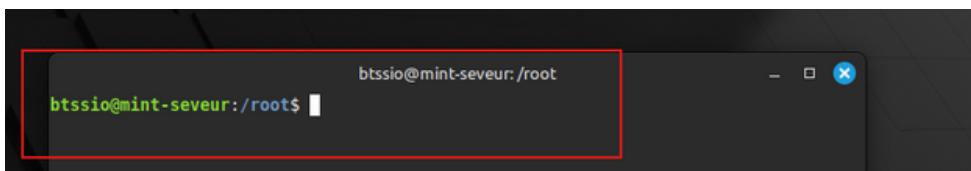
Afin de prévenir les erreurs nous allons faire des mise à jour de notre système avec la commande "`sudo apt update && sudo apt upgrade -y`" et installer Google-authenticator PAM avec la commande "`sudo apt install libpam-google-authenticator -y`"

Création de l'utilisateur

Maintenant nous allons créer un nouvel utilisateur "btssio" et effectuer une élévation de privilèges pour ce compte, nous allons utiliser la commande "`sudo adduser btssio`" et le rajouter par la suite au groupe "sudo" avec la commande "`sudo adduser btssio sudo`"

```
Retapez le nouveau mot de passe :
passwd : mot de passe mis à jour avec succès
Modifier les informations associées à un utilisateur pour btssiosudo
Entrer la nouvelle valeur, ou appuyer sur ENTER pour la valeur par défaut
NOM []:
Numéro de chambre []:
Téléphone professionnel []:
Téléphone personnel []:
Autre []:
Ces informations sont-elles correctes ? [0/n] n
Modifier les informations associées à un utilisateur pour btssiosudo
Entrer la nouvelle valeur, ou appuyer sur ENTER pour la valeur par défaut
NOM []:
Numéro de chambre []:
Téléphone professionnel []:
Téléphone personnel []:
Autre []:
Ces informations sont-elles correctes ? [0/n] o
info: Ajout du nouvel utilisateur « btssiosudo » aux groupes supplémentaires « u
sers » ...
info: Ajout de l'utilisateur « btssiosudo » au groupe « users » ...
root@mint-seveur:~# sudo adduser btssio sudo
info: Ajout de l'utilisateur « btssio » au groupe « sudo » ...
root@mint-seveur:~#
```

Nous allons enfin nous connecter au compte de notre utilisateur.

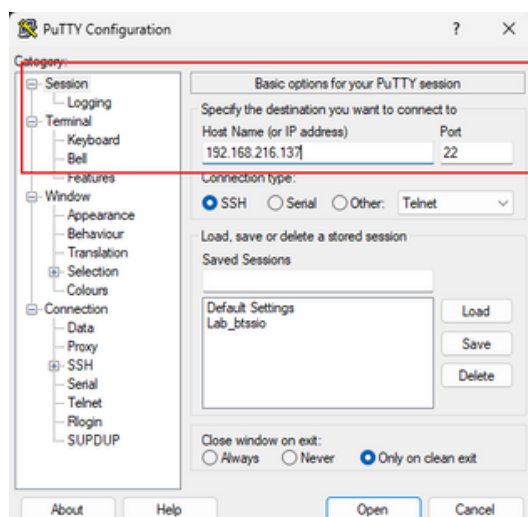


Installation du client

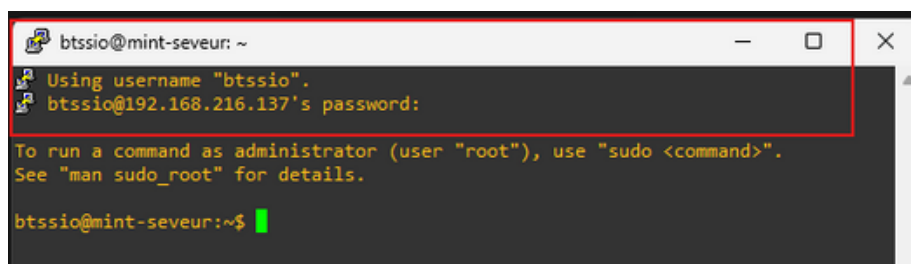


Nous allons générer la connexion coté client en se servant de PuTTY

nous allons d'abord rentrer l'adresse ip dans l'onglet "Session" et ensuite dans "Connexion/Data"; rentrer btssio qui est notre utilisateur dans le champs "Auto-login username"



Nous sommes enfin connecté en ssh avec putty avec notre serveur.



Mise en place d'une authentification SSH 2FA avec mot de passe et TOTP

TOTP

```
btssio@mint-seveur:/root$ echo "HOTP/T30/6 btssio - $KEY" >> /etc/security/users.oath
bash: /etc/security/users.oath: Permission non accordée
btssio@mint-seveur:/root$ sudo chown btssio/etc/security
chown: op rande manquant apr s «btssio/etc/security»
Saisissez « chown --help » pour plus d'informations.
btssio@mint-seveur:/root$ sudo chown btssio /etc/security
btssio@mint-seveur:/root$
btssio@mint-seveur:/root$ cat /etc/security/users.oath
HOTP/T30/6 btssio -
btssio@mint-seveur:/root$
```

G n ration du QR code

Nous allons r cup rer le secret en base 32 pour g n rer un QR code au niveau de l'application sur le smartphone :

```
oathtool -v -d 6 65f43c705ce51c9c058ec8bb4b7f64b656681866
```

Le cl  Base32 secret obtenu gr ce oathtool :

MX2DY4C44UOJYBMOZC5UW73EWZLGQGDG'

```
btssio@mint-seveur: ~
Les NOUVEAUX paquets suivants seront install s :
  qrencode
0 mis   jour, 1 nouvellement install s, 0   enlever et 4 non mis   jour.
Il est n cessaire de prendre 26,1 ko dans les archives.
Apr s cette op ration, 64,5 ko d'espace disque suppl mentaires seront utilis s.
R ception de :1 http://archive.ubuntu.com/ubuntu noble/universe amd64 qrencode a
md64 4.1.1-1build2 [26,1 kB]
26,1 ko r ceptionn s en 0s (241 ko/s)
S lection du paquet qrencode pr c demment d s lectionn .
(Lecture de la base de donn es... 498019 fichiers et r pertoires d j  install s.
)
Pr paration du d paquetage de .../qrencode_4.1.1-1build2_amd64.deb ...
D paquetage de qrencode (4.1.1-1build2) ...
Param trage de qrencode (4.1.1-1build2) ...
Traitement des actions diff r es (« triggers ») pour man-db (2.12.0-4build2) ...
btssio@mint-seveur:~$ qrencode -o btssio.png 'otpauth://totp/btssio@192.168.216.
137 ?secret=MX2DY4C44UOJYBMOZC5UW73EWZLGQGDG'
btssio@mint-seveur:~$
btssio@mint-seveur:~$
```

Le fichier a bien  t  cr  

```
btssio@mint-seveur: ~
btssio@mint-seveur:~$ ls
btssio.png
btssio@mint-seveur:~$
```

Téléchargement du qrcode en png depuis la machine client

```
C:\Users\Verand NGUIE>echo %USERNAME%
Verand NGUIE

C:\Users\Verand NGUIE>scp btssio@192.168.216.137:~/btssio.png "C:\Users\Verand NGUIE\Downloads\LabOPTbtssio.png"
The authenticity of host '192.168.216.137 (192.168.216.137)' can't be established.
ED25519 key fingerprint is SHA256:fkdrJP4q8/oFrdolK+f/Q1ef+atRno0AG6cs+VC2vM.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])?
Warning: Permanently added '192.168.216.137' (ED25519) to the list of known hosts.
btssio@192.168.216.137's password:
btssio.png                                     100% 480 156.3KB/s 00:00

C:\Users\Verand NGUIE>
```

Le qrcode généré



Configuration du service d'authentification PAM

Ici nous allons configurer PAM (Pluggable Authentication Modules) en tapant “**sudo nano /etc/pam.d/sshd**” au niveau du terminal où nous allons commenter avec # la ligne @include common-auth pour permettre l'authentification OTP

```
btssio@mint-seveur: ~
GNU nano 7.2 /etc/pam.d/sshd
# PAM configuration for the Secure Shell service

# Standard Un*x authentication.
#@include common-auth
auth required pam_unix.so nullok_secure.
auth required pam_oath.so usersfile=/etc/security/users.oath windows=20digits=6.
# Disallow non-root logins when /etc/nologin exists.
account required pam_nologin.so

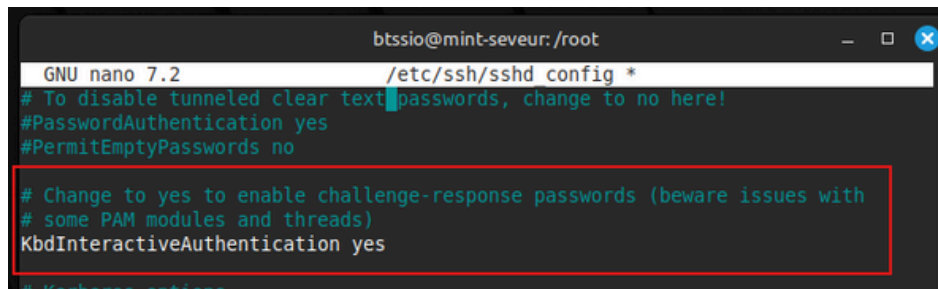
# Uncomment and edit /etc/security/access.conf if you need to set complex
# access limits that are hard to express in sshd_config.
# account required pam_access.so

# Standard Un*x authorization.
@include common-account

# SELinux needs to be the first session rule. This ensures that any
# lingering context has been cleared. Without this it is possible that a
# module could execute code in the wrong domain.
session [success=ok ignore=ignore module=unknown=ignore default=bad] pam>
[ Lecture de 56 lignes ]
^G Aide ^O Écrire ^W Chercher ^K Couper ^T Exécuter ^C Emplacement
^X Quitter ^R Lire fich. ^A Remplacer ^U Coller ^J Justifier ^_ Aller ligne
```

Configuration du service SSH

Nous allons éditer le fichier de configuration du service SSH afin de définir l'usage de l'authentification 2FA et redémarrer le service ssh par la suite.



```
btssio@mint-seveur: /root
GNU nano 7.2 /etc/ssh/sshd_config *
# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication yes
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
KbdInteractiveAuthentication yes
# KbdInteractiveAuthentication no
```

Tester l'authentification 2FA

Nous allons fermer la connexion entre le serveur Linux Mint avec PuTTY
Reouvrir une connexion SSH grâce à PuTTY en sélectionnant la session "Lab_btssio"
et cliquer sur "Open".
Entrer le mot de passe
Enter l'OTP indiqué par votre application sur votre smartphone.

Félicitations ! Vous êtes connecté !

